

TASK1: VULNERABILITY ASSESSMENT REPORT

Target Website: Altoro Mutual (<http://demo.testfire.net>)

Domain: Cyber Security Internship

Submitted By: Sanjana R Kulkarni

Organization: Future Interns

Date: 10/4/2026

1. Introduction

This report presents the results of a vulnerability assessment conducted on the Altoro Mutual demo website. The purpose of this assessment is to identify security weaknesses and analyze potential risks that could affect the confidentiality, integrity, and availability of the system.

The assessment was carried out using standard cybersecurity tools and techniques. The findings are documented along with their risk levels and recommended mitigation strategies.

2. Methodology

The following tools and methods were used during the assessment:

- **Nmap:** Used for network scanning to identify open ports and services
- **OWASP ZAP:** Used for automated vulnerability scanning
- **Browser Developer Tools:** Used for manual inspection of website elements

Steps Performed:

1. Identified the target website
2. Performed port scanning using Nmap
3. Conducted automated scanning using OWASP ZAP
4. Analyzed vulnerabilities and classified risk levels
5. Documented findings with screenshots

3. Findings

Vulnerability 1: Open Ports & Services Exposure

- **Description:**
The Nmap scan revealed multiple open ports such as 80 (HTTP), 443 (HTTPS), and 8085.
- **Risk Level:** Medium
- **Impact:**
Open ports increase the attack surface and can allow attackers to exploit vulnerable services.

Screenshot:



- **Solution:**
Close unused ports and apply firewall restrictions to limit access.

Vulnerability 2: Content Security Policy (CSP) Header Not Set

- **Description:**
The application does not have a Content Security Policy header configured.
- **Risk Level:** Medium
- **Impact:**
This may allow attackers to execute malicious scripts (XSS attacks).

Screenshot:

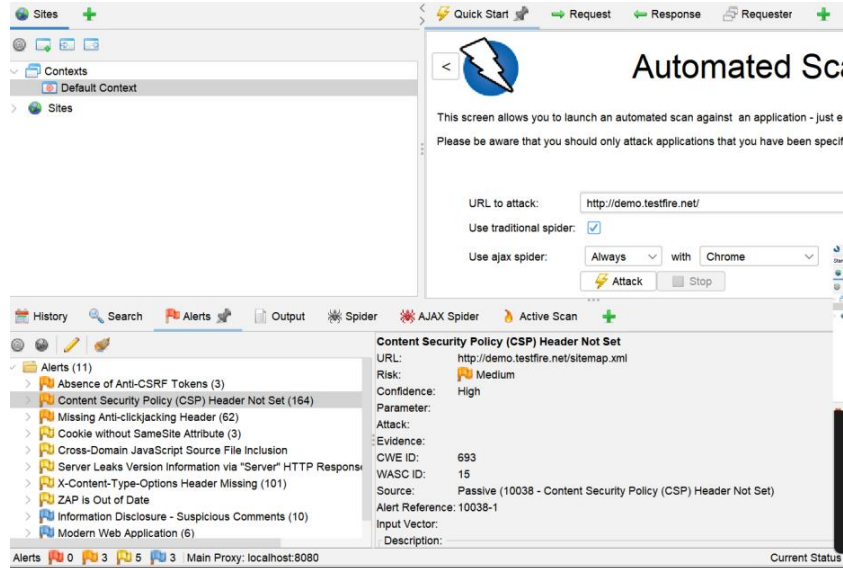


Figure: CSP Header Not Set detected in OWASP ZAP

- **Solution:**
Configure a proper Content Security Policy to restrict content sources.

Vulnerability 3: Missing Anti-CSRF Tokens

- **Description:**
The application does not implement CSRF protection.
- **Risk Level:** Medium
- **Impact:**
Attackers can perform actions on behalf of users without their consent.

Screenshot:

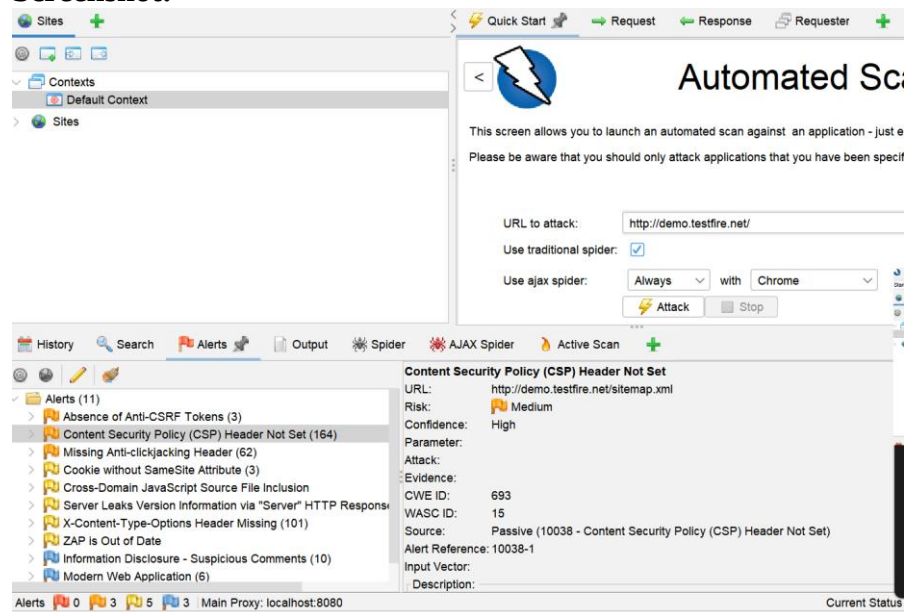


Figure: Absence of Anti-CSRF Tokens detected using OWASP ZAP

- **Solution:**
Implement CSRF tokens in forms.

Vulnerability 4: Missing Security Headers

- **Issues Found:**
 - Missing X-Content-Type-Options
 - Missing Anti-clickjacking header
 - Cookie without SameSite attribute
- **Risk Level:** Low–Medium
- **Impact:**
These issues may lead to clickjacking and session attacks.
- **Screenshot:**

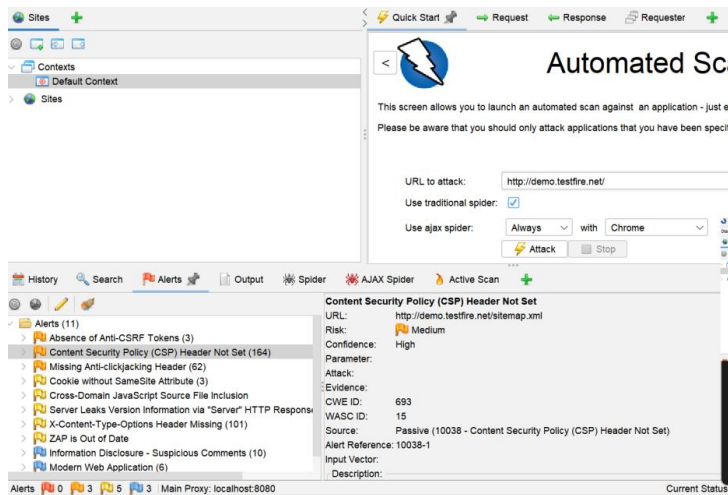
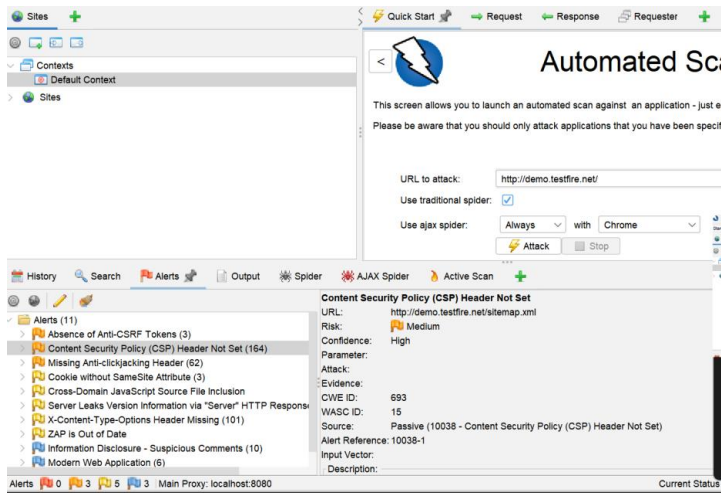


Figure: Missing security headers identified using OWASP ZAP

- **Solution:**
Add proper HTTP security headers.

Vulnerability 5: Information Disclosure

- **Description:**
The server reveals version details and sensitive comments.
- **Risk Level:** Low
- **Impact:**
Attackers can use this information to plan attacks.
- **Screenshot:**



- **Solution:**
Remove sensitive information and disable server version exposure.

4. Conclusion

The vulnerability assessment identified several security issues including missing headers, lack of CSRF protection, and exposed services. While some vulnerabilities are moderate, they can be exploited if left unaddressed.

By implementing the recommended solutions, the overall security posture of the application can be significantly improved.